B02 — Panduan verifikasi untuk penerima SBOM

© 2026 Dea Saka Kurnia Putra. All rights reserved.

Kontrol dokumen	
ID dokumen	B02
Judul	Panduan verifikasi untuk penerima SBOM
Versi	0.1.0 (= versi aplikasi) · commit `fd1db6c`
Tanggal	2026-10-25
Status	Draf
Klasifikasi	Publik
Pemilik	Dea Saka Kurnia Putra
Penyusun	Dibangkitkan oleh `scripts/compliance/*` (Claude Code) dari sumber kebenaran repo
Penyetuju	[KONFIRMASI] — penyetuju dokumen belum ditetapkan
Lingkup	Penerima SBOM Finandex (pengguna, auditor, mitra)
Standar acuan	Sigstore (cosign) keyless; GitHub artifact attestations (in-toto / SLSA provenance); CycloneDX 1.7 VEX
Dokumen terkait	B01, B04

Riwayat perubahan

Versi	Tanggal	Perubahan
0.1.0	2026-10-25	Versi pertama, dibangkitkan dari artefak SBOM rilis ini.

1. Unduh

```
gh release download v0.1.0 -R DSKPutra/finandex -p 'finandex-*' -p SHA256SUMS -p '*.sigstore.json'
```

atau dari aplikasi: **/legal/sbom** → `/sbom/0.1.0/…`.

2. Periksa integritas (hash)

```
shasum -a 256 -c SHA256SUMS
```

Setiap baris harus `OK`. `SHA256SUMS` sendiri ikut ditandatangani.

3. Periksa tanda tangan Sigstore

```
cosign verify-blob finandex-0.1.0.cdx.json \
  --bundle finandex-0.1.0.cdx.json.sigstore.json \
  --certificate-identity-regexp 'https://github.com/DSKPutra/finandex/.github/workflows/compl
iance.yml@.*' \
  --certificate-oidc-issuer https://token.actions.githubusercontent.com
```

Identitas penanda tangan harus workflow `compliance.yml` milik repo `DSKPutra/finandex`.

4. Periksa atestasi GitHub

```
gh attestation verify finandex-web-dist.tgz -R DSKPutra/finandex
gh attestation verify finandex-0.1.0.cdx.json -R DSKPutra/finandex
```

Atestasi SBOM mengikat SBOM induk ke *digest* artefak web; atestasi *build provenance* mengikat artefak & SBOM ke commit dan workflow yang membangunnya.

5. Validasi isi

```
npm run sbom:verify   # skema CycloneDX 1.7, elemen minimum CISA 2026, cakupan, VEX, kebocora
n
sbomqs score finandex-0.1.0.cdx.json
```

6. Membaca VEX

`finandex-0.1.0.vex.cdx.json` berisi satu pernyataan per temuan pemindai. Status: `not_affected` (dengan `justification`, mis. `code_not_present` = komponen tidak ada di artefak yang didistribusikan), `affected` (dengan tindakan), `fixed`, atau `in_triage` (sedang diselidiki). Register lengkap: B04.

English

Download from the GitHub Release or **/legal/sbom**; check `SHA256SUMS` with `shasum -a 256 -c`; verify Sigstore bundles with `cosign verify-blob --bundle … --certificate-identity-regexp '…/compliance.yml@.*' --certificate-oidc-issuer https://token.actions.githubusercontent.com`; verify attestations with `gh attestation verify <file> -R DSKPutra/finandex`; read the VEX statuses as above.

© 2026 Dea Saka Kurnia Putra. All rights reserved. — Finandex